OKX DEV DAY 2026 · BUILD A COMPANY · REMOTE

GuardianMCP
Pay-Safe

An agent that checks other agents' payments
before they get signed.

Ten free tools, one paid. It runs inside OKX's own CLI, on the pay command itself.

Team LNO Alpha · guardian-mcp-rho.vercel.app · github.com/InkoStrategy/guardian-mcp

THE GAP

An agent pays whatever the 402 tells it to.

A buyer agent calls a paid endpoint, gets an HTTP 402 challenge written by the seller, signs it and pays — in a second, with no human in the loop.

Nobody checks the challenge

The 402 is seller-written. Nothing compares it with what that seller actually listed on the marketplace.

Wallet firewalls are too late

Blockaid, Blowfish, Wallet Guard and ScamSniffer simulate a transaction that is already signed, or flag known-bad addresses.

So the gap is pre-signature

Between “the seller said pay this” and “the wallet signed it” there is no independent check at all.

WHAT WE FOUND — WITH OKX'S OWN CLI

The 402 body and its header name different wallets.

402 JSON BODY — WHAT THE AGENT READS

`0xe1c6…f67b`

Matches the marketplace listing. Looks correct to anything reading the body.

PAYMENT-REQUIRED HEADER — WHAT THE WALLET SIGNS

`0x5b0c…1A09`

The CLI persists this one as the entry to sign, and its confirmation line never prints a payee.

The agent is shown one payment while the wallet signs another. Guardian returns DENY without needing to know the listed payee.

```
curl -s -X POST …/probe-payment -d '{"url":"…/demo/x402/header-body-split"}' → DENY challenge_header_body_mismatch
```

AND ONE YOU CANNOT SEE

Two characters that make a signature worthless.

```
USD₮0    what the token contract on X Layer actually uses
USDTₒ    what live paid OKX.AI listings declare in their 402
```

₮ is U+20AE followed by a digit zero. ₒ is the letter T and a subscript zero. A signature built from the declared domain **never verifies on-chain**, so those payments cannot settle.

We read the contract's own DOMAIN_SEPARATOR live and show which pair it accepts. Our daily scans have flagged this on up to nine listings at once.

THE PRODUCT

Check the challenge against the listing, before signing.

Guardian fetches the paid endpoint **once, without paying**, reads the 402, and compares price, token, endpoint, payee and EIP-712 domain against the OKX.AI listing and the token contract.

ALLOW

Everything matches the listing. The agent pays, and the wallet is bound to exactly what was checked.

WARN

Something is off but not proof of theft — a broken signature domain, no listing to compare against.

DENY

Price inflated, payee swapped, token substituted, shell payload in the endpoint. With the evidence.

Shipped as an MCP server with ten tools — nine free, one paid at 0.099 USD₮0 over x402.

WHERE IT LIVES

Inside OKX’s own CLI, on the pay command.

A Claude Code `PreToolUse` hook sits on `onchainos payment pay`. It blocks the payment when the verdict is DENY, when no verdict is bound to that paymentId, or when the quote changed after it was checked.

Bound to the exact quote

The CLI persists each quote to disk and signs from that file. Guardian fingerprints the entry that will be signed, so nothing can change between the check and the signature.

Proven on a real agent

Three unedited headless agent runs: the hook blocks a scam payment live, holds an honest one for the owner, and the agent refuses a listing that injects shell commands.

Watch it: guardian-mcp-rho.vercel.app/agent-runs — raw transcripts, nothing edited

EVIDENCE, NOT CLAIMS

Everything here is checkable in a browser.

24
dated daily scans of every paid OKX.AI service since 16 Sep

41
payment rules, 172 passing tests

10
MCP tools discovered by OKX's own CLI

1
real payment settled on X Layer through the guarded flow

The scan runs itself every day and refuses to publish a run that looks broken. The marketplace it watches churns between 56 and 80 paid services — every new listing is a seller hand-writing a fresh 402 challenge that nothing has checked.

/trust · /trust-scans · /company · /pay-safe · /mcp

WHERE WE HONESTLY ARE

What is true today, and what we want next.

BUILT AND LIVE

- MCP server, payment gate and CLI hook, all deployed
- A new attack class found in a live marketplace
- A self-running daily audit of that marketplace

NOT TRUE YET — STATED PLAINLY

- Zero external users and zero revenue
- Zero paid `guard` calls from anyone but us
- Our OKX.AI listing is still under review

We would rather be judged on a product that works and numbers that are real than on traction we do not have.

Looking for design partners: agent owners paying for anything on OKX.AI. Telegram @d_berlinskiy